Access Control Policy and Procedures (HPMG, practice document)

Nov 1, 2026 · @Musah

1. Document control

This policy sets how Harbor Point Medical Group (HPMG) controls access to its information systems. HPMG is a fictional organization, and the document exists only for assessment practice.

Item	Value
Document ID	HPMG-POL-AC-001
Version	1.0
Policy owner (designated official)	Information Security Officer (ISO)
Approved by	Chief Executive Officer (CEO)
Effective date	2026-11-01
Next scheduled review	2027-11-01
Classification	Internal

2. Purpose

This policy ensures that only authorized people can reach the information and systems they need to do their jobs, and nothing more. It protects the confidentiality, integrity and availability of patient and business information. It also supports the access control requirements of the HIPAA Security Rule and the NIST SP 800-53 access control (AC) family.

3. Scope

This policy applies at two levels: organization-level for all HPMG information systems, and system-level for the system named below. It covers every employee, contractor and vendor who has access to HPMG systems or data.

System-level scope: DC01, a Windows Server 2022 domain controller for the ad.northstar.test Active Directory domain (NetBIOS name NORTHSTAR). This includes its user and service accounts, security groups, Group Policy Objects, and every local and remote administration path to the server.

The procedures in Section 9 apply to DC01 and to any system that authenticates users through it.

4. Roles and responsibilities

The Information Security Officer is the designated official who manages development, documentation and dissemination of this policy and its procedures. Other roles carry the duties below.

Role	Responsibilities
Chief Executive Officer	Approves this policy, funds the access control program, and holds managers accountable for compliance.
Information Security Officer (ISO)	Develops, documents and disseminates the policy and procedures. Reviews and updates them on the schedule in Section 11. Tracks exceptions and reports access control risks to the CEO.
System Owner (Director of IT)	Accountable for DC01. Approves access to the system and confirms the procedures in Section 9 are followed.
System Administrators	Create, change and disable accounts only from approved requests. Keep records of every change. Use separate administrator accounts for privileged work.
Human Resources	Notifies IT of hires, role changes and terminations within one business day.

Role	Responsibilities
Managers and data owners	Request and approve access for their staff. Complete the quarterly access review for their teams.
All users	Protect their credentials, use only the access they were granted, and report suspected misuse to the ISO.

5. Management commitment

HPMG executive leadership is committed to controlling access to patient and business information. Leadership approves this policy, assigns the resources needed to carry it out, and requires every manager to enforce it in their area. Access control failures are treated as business risks and reported to the CEO.

6. Coordination among organizational entities

Access control only works when several groups act together. HPMG coordinates as follows:

- **IT and HR:** HR sends hire, transfer and termination notices to the IT service desk. IT acts on them within the timeframes in Section 9.
- **IT and Compliance:** Compliance receives the quarterly access review results and uses them in HIPAA risk analysis and audits.
- **IT and Facilities:** Facilities and IT share badge and server room access lists so that physical and logical access are removed together.
- **Vendors and contractors:** Contracts require vendors to follow this policy. The sponsoring manager requests and reviews vendor accounts.
- **Security governance:** The ISO, Director of IT and Compliance lead meet monthly to review access requests, exceptions and open findings.

7. Compliance

This policy is written to be consistent with the laws, regulations, standards and guidelines that apply to HPMG. These include the HIPAA Security Rule (45 CFR 164.308(a)(4) and 164.312(a)), applicable New York State requirements, contractual obligations, and NIST SP

800-53 Rev 5 and SP 800-53B as the organization's control baseline. Where HPMG contracts require compliance with Executive Orders or agency directives, those requirements apply as well.

Enforcement. Violations may lead to disciplinary action up to and including termination, and to contract termination for vendors. Suspected violations are reported to the ISO.

Exceptions. A person who cannot meet a requirement submits a written exception request to the ISO that states the reason, the risk, and any compensating controls. The ISO and System Owner approve or deny it. Approved exceptions last no longer than 12 months and are recorded in the exception register.

8. Policy statements

HPMG commits to the following rules for all in-scope systems, including DC01.

1. **Least privilege.** Access is granted on a need-to-know basis and limited to what a person needs for their job.
2. **Unique accounts.** Every person has their own account. Shared or generic accounts are prohibited unless the ISO approves a written exception.
3. **Approval before access.** No account is created or changed without a documented request approved by the person's manager and by the System Owner.
4. **Privileged access.** Administrator rights are limited to named System Administrators. Administrators use a separate account for privileged tasks, and privileged accounts do not use email or web browsing.
5. **Strong authentication.** Multi-factor authentication is required for privileged accounts and for all remote access.
6. **Timely removal.** Accounts are disabled within 24 hours of a termination notice, and access is adjusted within 24 hours of a role change.
7. **Inactive and temporary accounts.** Accounts inactive for 90 days are disabled. Temporary and emergency accounts expire automatically within 30 days.
8. **Periodic review.** Privileged accounts are reviewed monthly. All other accounts are reviewed quarterly. Findings are corrected within 30 days.
9. **Session protection.** Sessions lock after 15 minutes of inactivity. Accounts lock after 5 consecutive invalid logon attempts in 15 minutes.
10. **Accountability.** Account creation, changes, privileged use and failed logons are logged and retained under the HPMG audit policy.

9. Access control procedures

These procedures put the policy in Section 8 into practice for DC01 and the ad.northstar.test domain.

9.1 Request and approve access

1. The requester's manager submits an access request in the IT service desk system. The request names the person, job role, systems, groups and business reason.
2. The manager approves the request, then the System Owner approves it.
3. The service desk attaches both approvals to the ticket. A request with a missing approval is returned.

9.2 Create the account

1. A System Administrator creates the account in Active Directory Users and Computers using the naming standard (first initial plus last name).
2. The administrator places the account in the organizational unit for the person's department and adds it only to the security groups listed on the approved ticket.
3. The administrator sets a unique temporary password, requires a change at first logon, and sends it to the manager by a separate channel.
4. The administrator records the account, groups and ticket number in the account register, then closes the ticket.

9.3 Privileged access

1. Administrator rights come from membership in Domain Admins, Enterprise Admins, Schema Admins or Administrators. Only the System Owner can approve membership.
2. Each administrator has a standard account for daily work and a separate named administrator account for privileged tasks.
3. The ISO reviews membership of these groups every month and removes anyone without a current approved need.

9.4 Change of role

1. HR notifies the service desk within one business day of a transfer or role change.
2. The new manager submits a request under Section 9.1. The service desk removes access that the new role no longer needs within 24 hours.

9.5 Disable and remove accounts

1. **Termination:** On a termination notice, a System Administrator disables the account within 24 hours, removes it from all security groups, and records the time on the ticket. Accounts are deleted after 90 days unless a legal hold applies.
2. **Inactivity:** A monthly report lists accounts with no logon for 90 days. Administrators disable them and notify the manager.
3. **Temporary and emergency accounts:** These are created with an expiration date no later than 30 days out.

9.6 Access review

1. Each month the ISO reviews all privileged group members.
2. Each quarter the service desk sends every manager a list of their staff accounts and group memberships.
3. Managers confirm or request removal of each entry within 10 business days. The ISO follows up on late responses.
4. Administrators complete required removals within 30 days. The ISO files the signed results as the access review record.

9.7 Emergency access

1. The System Owner may approve emergency access by phone or email when patient care or an outage requires it.
2. The administrator documents the approval on a ticket within one business day.
3. Emergency access expires in 72 hours unless a normal request under Section 9.1 is approved.

9.8 Records

The service desk and ISO keep tickets, approvals, the account register, access review results and the exception register for at least six years, in line with HIPAA documentation requirements.

10. Dissemination

The ISO disseminates this policy and its procedures to all system administrators and IT staff, system owners, department managers, Human Resources and Compliance staff. All other workforce members receive the policy through the annual security awareness acknowledgment.

1. The ISO publishes the current version in the intranet policy library under Security Policies.
2. The ISO emails the policy and procedures to the roles above whenever a new version is released.
3. Recipients acknowledge receipt in the learning management system. New hires acknowledge within 5 business days of their start date.
4. The ISO keeps the distribution list and acknowledgment report as the dissemination record.

11. Review and update

The ISO reviews and updates this policy and its procedures every 12 months, and also after any of the following events:

- A significant security incident involving unauthorized access or misuse of privileges
- A major change to DC01 or the HPMG environment, such as a migration, new domain trust or new remote access method
- A change in applicable law, regulation or contract requirements
- A finding from an assessment, audit or access review that shows a gap in this policy

Each review is recorded in the revision history. If nothing changes, the entry says the review was completed with no changes.

Revision history

Version	Date	Author	Summary
1.0	2026-11-01	Information Security Officer	Initial release of the policy and procedures

Approval

Role	Name	Date approved
Information Security Officer	[enter name]	2026-11-01
Chief Executive Officer	[enter name]	2026-11-01